BÁO CÁO ĐỒ ÁN CƠ SỞ/ CHUYÊN NGÀNH HỌC KỲ I NĂM HỌC 2026 – 2027

Họ và tên: Lê Minh Nhật MSSV: 2380601546

Họ và tên: Nguyễn Minh Tuấn MSSV: 2380602459

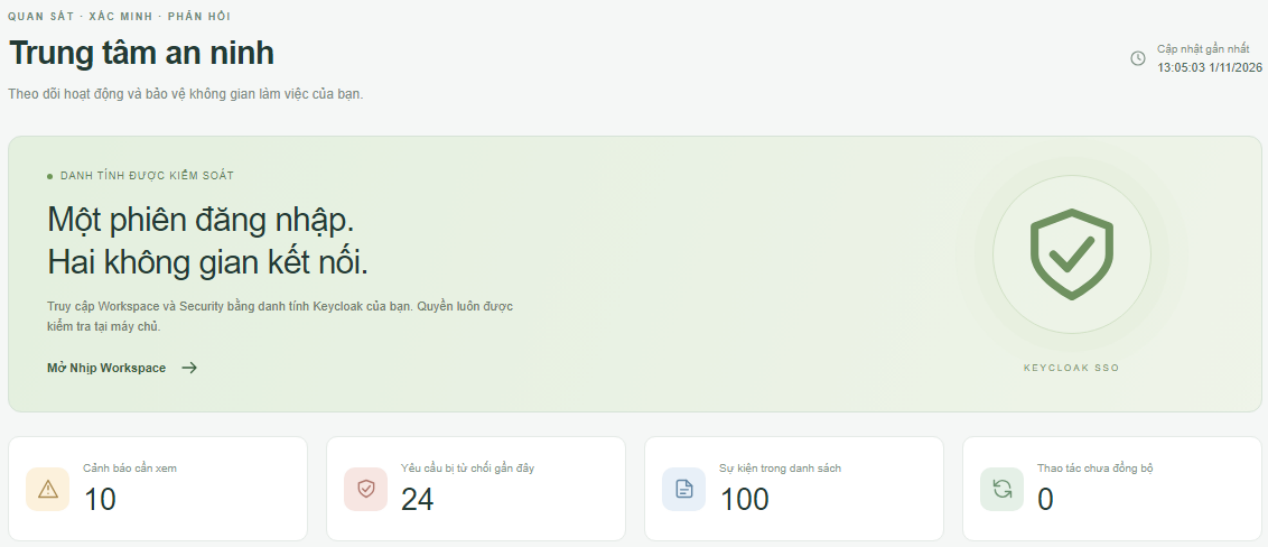
Lớp: 23DTHB7 Chuyên ngành: An Ninh Mạng Tuần số: 3–4

Đề tài đăng ký: XÂY DỰNG HỆ THỐNG IAM DỰA TRÊN KEYCLOAK THEO ĐỊNH HƯỚNG ZERO TRUST

Nội dung báo cáo: Kết quả tuần 3–4, đối chiếu minh chứng lưu ngày 01/11/2026 (UTC+7).

1. **Đến hiện tại nhóm đã hoàn thành được những thành phần nào của đề tài? Thành phần nào đã chạy thật, thành phần nào mới chỉ tìm hiểu/cài đặt?**

Hạng mục	Kết quả và trạng thái
Tuần 3 – Web A, RBAC	Đã chạy: Keycloak + PostgreSQL, Web A React, API Express; đăng nhập PKCE S256; 4 role, API trả 200/401/403 đúng quyền.
Tuần 4 – Web B, SSO	Đã chạy: Web B độc lập, SSO hai chiều, logout liên ứng dụng, HTTPS LAN/VPN; token và audience riêng cho mỗi client.
Chức năng mở rộng	Đã có minh chứng: tạo/sửa/khóa tài khoản, đổi role, thu hồi phiên; log, cảnh báo, thông báo, tìm kiếm và xuất CSV.
Chưa hoàn tất	MFA/OTP thực tế, vòng đời refresh đầy đủ, HTTPS máy khách thứ hai; LDAP/AD, audit PostgreSQL tập trung và Python Detection chưa nghiệm thu.

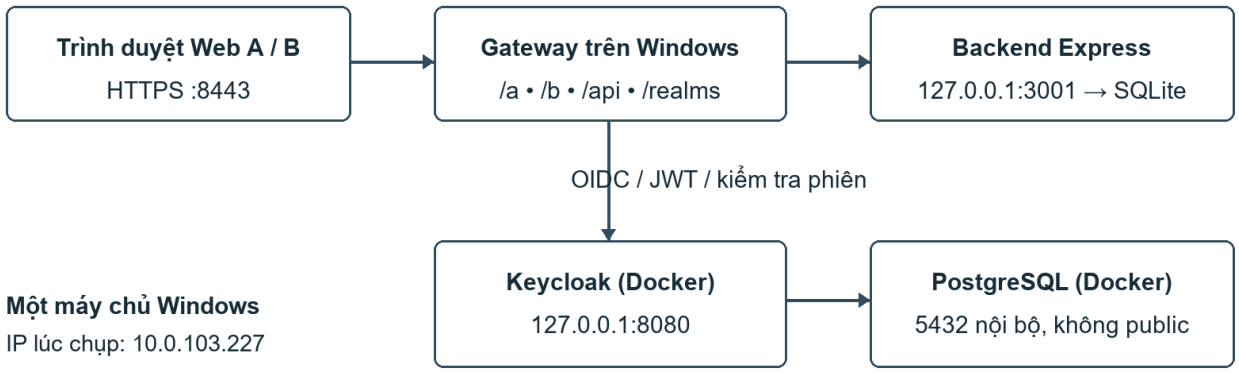


Hình 1. Web B chạy thật, phiên đã xác thực và các bộ đếm từ API. Phóng to vùng nội dung ảnh gốc 02-web-b-admin.png; không sửa dữ liệu.

2. **Mô hình triển khai hiện tại của nhóm gồm những máy/VM nào? Mỗi máy làm gì, IP nào, luồng dữ liệu hoặc log đi như thế nào?**

Mô hình hiện tại dùng một máy Windows chạy Docker Desktop/WSL2 và các tiến trình ứng dụng; chưa tách Web A/B thành hai máy chủ hoặc hai VM riêng. IP dưới đây là địa chỉ tại thời điểm lưu minh chứng, không khẳng định là IP hiện tại.

Thành phần / nơi chạy	Địa chỉ và nhiệm vụ
Máy chủ Windows	10.0.103.227; gateway HTTPS cổng 8443 phục vụ /a (Web A), /b (Web B), /api và các đường dẫn OIDC.
Backend Express / host	127.0.0.1:3001; xác minh JWT, kiểm tra phiên/quyền, xử lý nghiệp vụ, ghi audit/cảnh báo vào SQLite.
Keycloak / container	Cổng host 127.0.0.1:8080; realm company-iam, xác thực người dùng, cấp token và quản lý phiên SSO.
PostgreSQL / container	Cổng 5432 trong mạng Docker nội bộ; lưu dữ liệu Keycloak. Không mở cổng DB ra LAN.
Máy khách LAN/VPN	Trình duyệt truy cập https://10.0.103.227:8443; mỗi hồ sơ trình duyệt có phiên riêng. Chưa xác nhận đầy đủ đăng nhập với CA tin cậy trên máy thứ hai.



Hình 2. Sơ đồ mô hình tại mốc báo cáo. Các dịch vụ đặt trên cùng máy chủ; PostgreSQL dành cho Keycloak, SQLite dành cho ứng dụng.

Luồng dữ liệu: trình duyệt → gateway → Keycloak để đăng nhập; sau đó trình duyệt gửi token tới API. Backend xác minh chữ ký, issuer, audience, phiên và role rồi trả dữ liệu hoặc từ chối. ALLOW/DENY được ghi vào SQLite; collector lấy các sự kiện Keycloak được hỗ trợ, lưu chống trùng và tạo cảnh báo để Web B tra cứu.

3. **Nhóm đã kiểm chứng được ít nhất một luồng hoàn chỉnh chưa? Hãy chỉ rõ từ lúc phát sinh sự kiện đến khi hệ thống xử lý xong.**

Đã kiểm chứng được luồng sự kiện bảo mật hoàn chỉnh:

Bước 1 – Phát sinh: tài khoản thử nghiệm nhập sai mật khẩu tại Keycloak; Keycloak tạo sự kiện đăng nhập thất bại.

Bước 2 – Thu thập: collector của backend đọc sự kiện từ Keycloak, lưu vào SQLite và tạo cảnh báo đăng nhập thất bại.

Bước 3 – Xử lý, hiển thị: quản trị viên vào Web B, mở cảnh báo và xem tài khoản, thời điểm, số lần ghi nhận, hoạt động xác thực liên quan. Luồng kết thúc khi cảnh báo được lưu và hiển thị để điều tra.

Kết quả: ba kiểm tra "Failed login imported from actual Keycloak", "Failed login generates visible alert" và "Alert context includes related authentication" đều đạt trong lượt 23/23 kiểm tra API mở rộng (15:46–15:47 ngày 01/11/2026).



Hình 3. Ảnh chụp thật, phóng to phần đầu hộp Chi tiết cảnh báo: tài khoản uiops-1101154708, 1 lần, 15:47 ngày 01/11/2026. Nguồn: 06-alert-context.png.

Luồng SSO cũng đã chạy: đăng nhập admin01 tại Web A → mở Web B → Keycloak dùng phiên sẵn có, cấp token cho security-dashboard → API Web B trả 200. Chuyển ngược B → A không nhập lại mật khẩu; hai client dùng cùng sid nhưng có audience riêng. Kết quả logout và chặn token cũ được trình bày ở Hình 6.

4. Kịch bản bảo mật nào đã thử? Kết quả hiện tại là gì? Có chứng minh?

Tuần 3 đã gọi API bằng token từ Keycloak thật, kiểm tra đủ 16 tổ hợp người dùng/API. HTTP 200: cho phép; 401: thiếu hoặc mất hiệu lực xác thực; 403: đã xác thực nhưng không đủ quyền.

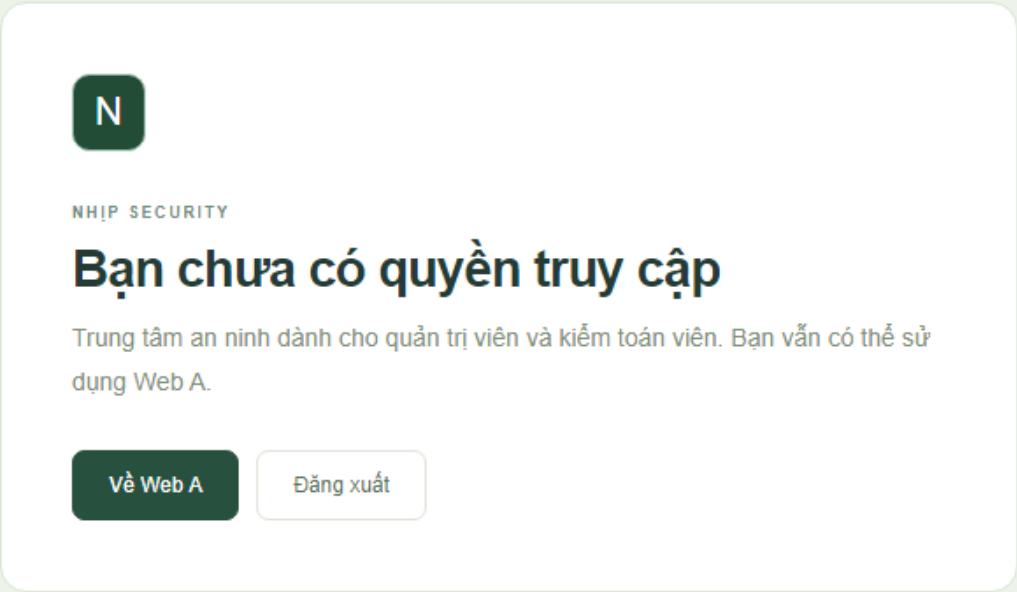
Tài khoản	/profile	/manager	/admin	/audit
employee01	200	403	403	403
manager01	200	200	403	403
admin01	200	200	200	200
auditor01	200	403	403	200

Bảng 1. Tất cả đường dẫn thuộc /api. Nguồn: verification.json, lượt 10:13 ngày 01/11/2026.



Hình 4. Trình bày lại hai phản hồi HTTP đã lưu trên nền trắng; đây là trích biên bản kết quả, không phải ảnh terminal.

Tuần 4: employee/manager vào Web B bị UI và API chặn (403), vẫn dùng Web A (200); auditor đọc Web B được (200) nhưng quản trị tài khoản bị chặn (403). Token Web B không dùng cho API chấm công (403). Logout ở A/B khiến token cũ bị từ chối (401); đường dẫn .env, khóa riêng và traversal bị chặn.



Hình 5. Ảnh chụp thật, phóng to thẻ nền trắng: employee01 bị từ chối ở Web B. Nguồn: 10-employee01-denied.png.

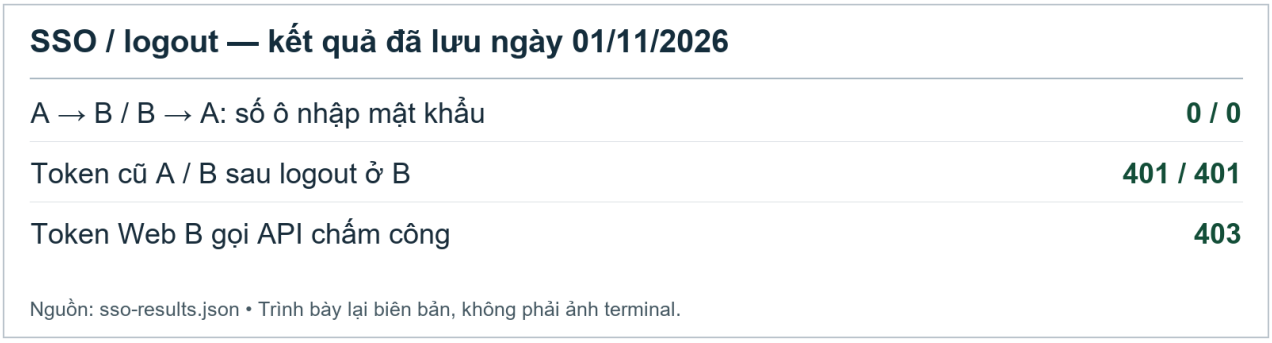
5. **So với đề cương ban đầu, nhóm có thay đổi kiến trúc, công nghệ hoặc phạm vi không? Nếu có, vì sao phải thay đổi?**

Nhóm giữ phạm vi IAM theo định hướng Zero Trust và Keycloak là trung tâm danh tính. Điều chỉnh cách triển khai: hai Web dùng chung một máy chủ/gateway để hoàn thiện SSO, RBAC và HTTPS trước; audit/cảnh báo đang dùng Express + SQLite để có luồng chạy được. PostgreSQL hiện chỉ lưu dữ liệu Keycloak. LDAP/AD, audit PostgreSQL tập trung và Python Detection vẫn là hạng mục kế tiếp, chưa coi là đã hoàn thành.

6. **Vấn đề kỹ thuật lớn nhất nhóm đang gặp là gì? Đã thử cách xử lý nào và kết quả ra sao?**

Khó khăn chính là đồng bộ logout/thu hồi phiên giữa hai Web: nếu chỉ kiểm tra chữ ký và hạn token, JWT cũ vẫn có thể dùng sau khi người dùng đăng xuất. Nhóm đã bổ sung xác minh sid với Keycloak (cache tối đa 5 giây); tab đang hoạt động kiểm tra mỗi 15 giây và khi nhận focus. Nếu Keycloak không liên lạc được, API trả 503 thay vì cho qua.

Kết quả: lượt 29/29 kiểm tra SSO xác nhận logout hai chiều, token A/B cũ bị trả 401. Giới hạn còn lại: tab nền bị đình chỉ có thể cập nhật muộn; máy khách thứ hai mới xác nhận truy cập HTTPS, chưa xác nhận trọn luồng CA tin cậy và đăng nhập.



Hình 6. Trích kết quả SSO/logout thật từ sso-results.json; không chạy lại hệ thống khi biên soạn báo cáo.

7. **Nhóm tự đánh giá đã hoàn thành khoảng bao nhiêu % đề tài? Phần nào đang có nguy cơ làm chậm tiến độ?**

Nhóm tự ước lượng khoảng 45% toàn bộ đề tài theo các hạng mục chức năng; đây là mức tự đánh giá, không phải tỷ lệ test đạt. Nền tảng IAM, hai Web, RBAC/SSO và một phần quản trị/audit đã chạy. Nguy cơ chậm tiến độ nằm ở MFA/refresh chưa nghiệm thu, LDAP/AD chưa tích hợp, độ tin cậy thu thập log và đồng bộ Keycloak–SQLite; audit tập trung, Python và đánh giá cuối kỳ còn ở phía sau.

8. Trong tuần 5–6, nhóm sẽ hoàn thành cụ thể những gì? Ai phụ trách từng phần?

Phân công dự kiến và sản phẩm cần bàn giao trong tuần 5–6:

Tuần	Lê Minh Nhật	Nguyễn Minh Tuấn
5	Hoàn thiện MFA/TOTP, required actions, refresh/phiên và thu hồi; rà soát quyền service account; chuẩn bị backup/rollback.	Tích hợp trạng thái MFA/phiên và lỗi vào Web A/B; củng cố gateway HTTPS; chuẩn bị collector checkpoint/retry và đối chiếu lỗi PARTIAL.
Đầu ra tuần 5	Có cấu hình/mã áp dụng được và hướng dẫn khôi phục. Khi chuyển sang nghiệm thu: xác nhận OTP đúng/sai/hết hạn, refresh lỗi và token sau thu hồi.	Có giao diện thông báo rõ trạng thái, log chẩn đoán; hoàn tất xác minh CA và đăng nhập từ máy khách thứ hai khi nghiệm thu.
6	Dựng OpenLDAP hoặc AD theo tài nguyên lab; tạo OU/group/user mẫu; cấu hình Keycloak LDAP Federation và đồng bộ thuộc tính/nhóm.	Tích hợp tài khoản LDAP với hai Web; đối chiếu role/trạng thái khi đổi nhóm hoặc khóa tài khoản; lưu ảnh và tổng hợp báo cáo.
Đầu ra tuần 6	Tài khoản LDAP đăng nhập qua Keycloak; có bảng mapping và kết quả đồng bộ.	Minh chứng đăng nhập A/B bằng LDAP, thay đổi quyền/trạng thái và API cho phép/từ chối tương ứng.

Hai thành viên cùng rà soát tích hợp. Mã tuần 5 đã được chuẩn bị ngày 04/11/2026 nhưng chưa kiểm thử/build hoặc áp dụng lên lab theo yêu cầu; không đưa phần này vào kết quả đạt của tuần 3–4.

Đối chiếu minh chứng

Mốc kết quả ngày 01/11/2026	Tệp nguồn trong word/minh_chung/tuan3_4/
Tuần 3: 40/40 kiểm tra cấu hình/HTTP; backend 54/54.	verification.json; backend-tuan3.tap
Tuần 4: SSO 29/29; backend 73/73, build A/B đạt.	sso-results.json; validation-summary.json (73 là bản tổng kết đã lưu, không phải TAP).
Mở rộng: backend 97/97, UI 42/42, API/trình duyệt 23/23.	backend-mo-rong.tap; ui-results.json; api-results.json

Các bộ số liệu thuộc những lượt riêng, không cộng thành một bộ test. Test backend dùng dữ liệu/khóa kiểm thử và mô phỏng phù hợp; kiểm tra HTTP/SSO/trình duyệt dùng Keycloak thật. Ảnh chụp gốc giữ nguyên trong thư mục minh chứng; báo cáo chỉ phóng to vùng cần đọc. Không lưu mật khẩu hoặc toàn bộ token.